

Cyber Tabletop Exercise

Ransomware Impact on Retail Payment Operations

Facilitation-ready exercise package

Improved version incorporating evaluation feedback on technical attack lifecycle and MITRE ATT&CK mapping

Item	Details
Exercise type	Facilitated tabletop exercise (TTX)
Audience	Executive, operational, cyber security, technology, payments, legal/compliance, communications, and business continuity stakeholders
Suggested duration	90 minutes (expandable to 120 minutes if all technical discussion prompts are played)
Primary environment in scope	Retail payment processing environment supporting ACH, SEPA, domestic transfer, and settlement workflows
Scenario source	Structured cyber scenario provided by the user; revised using uploaded evaluation feedback
Prepared date	13 July 2026

Exercise-only note

This scenario is fictional and designed to test decision-making, escalation, continuity, communications, and safe recovery. It should not be interpreted as a statement that any specific system, vendor, payment rail, or control is known to be vulnerable.

Facilitator Quick Reference

Topic	Facilitator cue
Core scenario	Financially motivated ransomware operator disrupts retail payment processing shortly before settlement cut-off.
Primary pressure	Containment versus continuity: whether to isolate payment systems while trying to complete priority payment obligations.
Main improvement applied	The attack path is now explicit: phishing-based access, execution, persistence, privilege escalation, credential access, discovery, lateral movement, command and control, defense evasion, ransomware deployment, and backup recovery inhibition.
Key governance point	SOC/IR leads technical containment under pre-approved emergency authorities; the crisis lead and business executives own business continuity, prioritization, stakeholder communication, and residual risk decisions.
Sensitive assumption	No confirmed data exfiltration in the core scenario. Any leak claim is treated as unverified unless the optional extension is played.

Exercise flow at a glance

Phase	Simulated time	Purpose
Pre-incident	T-10 to T-1 days	Initial compromise, credential access, discovery, lateral movement, staging
Inject 1	T-2 hours	Operational disruption; encryption alerts; initial scoping and incident classification
Inject 2	T-90 minutes	Executive decision point before settlement cut-off; isolation and fallback decisions
Inject 3	Several hours later	Containment stabilized; evidence preservation and restoration gates
Inject 4	Next business period	Controlled recovery, notifications, customer impact, post-incident management

Facilitation posture

Challenge participants to make time-bound decisions with incomplete information. Avoid letting the group wait for perfect certainty before classifying the incident, activating continuity options, preserving evidence, or preparing notifications.

1. Exercise Overview

Exercise title: Ransomware Impact on Retail Payment Operations

Exercise type: Facilitated tabletop exercise (TTX)

Audience: Executive, operational, cyber security, technology, payments, legal/compliance, communications, and business continuity stakeholders

Suggested duration: 90 minutes

Primary environment in scope: Retail payment processing environment supporting ACH, SEPA, domestic transfer, and settlement workflows

Purpose

This tabletop exercise tests the organization's ability to respond to a ransomware incident affecting payment processing systems shortly before settlement deadlines. The scenario stresses operational resilience, executive decision-making, continuity planning, communications, regulatory notification, and safe technical recovery under time pressure.

Revision focus

This version retains the original operational scenario while strengthening the cyber-specific elements requested in the evaluation feedback. The attack mechanics are now defined through a clear pre-impact sequence, the MITRE ATT&CK mapping is grounded in explicit scenario evidence, and speculative exfiltration is separated from the core scenario unless facilitators choose to play an optional extension.

2. Objectives

By the end of the exercise, participants should be able to:

- Assess and escalate a disruptive ransomware event affecting critical payment operations.
- Coordinate technical containment while preserving evidence and maintaining incident command discipline.
- Differentiate SOC/incident-response authorities from executive crisis management and business-continuity decision rights.
- Decide whether to isolate parts or all of the payment environment based on blast radius, settlement obligations, and residual compromise risk.
- Determine when and how to activate payment continuity fallback procedures.
- Prioritize payment flows based on business criticality, settlement obligations, customer impact, liquidity implications, and regulatory expectations.
- Interpret high-level technical indicators associated with initial access, execution, credential access, lateral movement, defense evasion, command and control, and impact.
- Coordinate executive, operational, legal, compliance, communications, and technology decisions under time pressure.
- Evaluate regulator, customer, partner, and internal notification triggers without over-confirming facts that remain uncertain.
- Identify restoration gates, backup validation requirements, credential-reset sequencing, and safe recovery priorities for the payment environment.
- Capture lessons learned and improvement actions across resilience, response, governance, payment continuity, and cyber control effectiveness.

3. Scope and Assumptions

In Scope

- Payment operations and settlement processing.
- Security operations, incident response, and forensic preservation.
- Executive crisis management and decision logging.
- Legal, compliance, privacy, and regulatory communications.
- Internal and external stakeholder communications.
- Business continuity and fallback processing for priority payment flows.
- Recovery decision-making for payment infrastructure, identity, backups, file shares, interfaces, and operational workstations.
- High-level attack lifecycle analysis and ATT&CK mapping for training purposes.

Assumptions

- The organization has documented incident response, crisis management, and payment continuity procedures.
- The payment environment includes production payment servers, operations shared drives, a payment operations jump/admin path, service accounts, user workstations, backup services, and interfaces to payment rails or clearing/settlement partners.
- The incident occurs approximately two hours before end-of-day settlement.
- The security team has confirmed ransomware activity on payment processing servers and operations file shares.
- The ransomware operator's initial access occurred days before encryption through a targeted phishing email to payment operations staff. This assumption is added to support a coherent attack lifecycle.
- A privileged payment operations service account is observed being used from an unusual source host. This does not mean the account owner acted maliciously; participants must avoid premature attribution.
- Attempted backup and local recovery disruption is observed, grounding the recovery-inhibition component of the scenario.
- No confirmed data exfiltration exists in the core scenario. Leak claims, if raised, are treated as unverified until evidence supports them.
- Participants should respond using current roles, responsibilities, systems, tolerances, and realistic internal processes.

Out of Scope

- Hands-on technical remediation or live containment actions.
- Detailed malware reverse engineering.
- Ransom negotiation tactics or payment decision-making beyond high-level governance considerations.
- Procurement or vendor contract negotiation.
- Legal advice specific to any one jurisdiction; participants should apply their own regulatory obligations and counsel input.

4. Rules of Engagement

- This is a no-fault learning exercise intended to improve readiness.
- Participants should respond as they would in a real event using current processes, authorities, escalation paths, and tools.
- Real incidents take priority; participants may step out if required.
- There are no perfect answers. The focus is on decision quality, clarity of accountability, coordination, and identification of gaps.
- Facilitators may provide additional details if discussion stalls or if a decision is required to move the scenario forward.

- Reasonable assumptions may be made where playbooks, facts, or approvals are not yet available. Assumptions should be stated aloud and logged.
- Do not fight the scenario. Treat all injects as exercise facts unless the facilitator states otherwise.
- Do not simulate actual malware, disable real controls, or perform any live testing during the tabletop.

5. Scenario Summary

A financially motivated ransomware operator gains access to the bank's internal environment several days before settlement disruption. The operator compromises a payment operations workstation through a targeted phishing lure, establishes persistence, performs discovery, accesses credential material, and uses valid accounts and remote services to move toward payment processing infrastructure. Shortly before settlement deadlines, ransomware is deployed against payment operations systems and shared drives.

Encryption begins affecting payment operations servers and shared resources. Failed payment batches accumulate, operational backlogs increase, and time-sensitive transfers are placed at risk. The SOC also observes attempts to interfere with local recovery artifacts and backup-related systems. The organization must decide whether to isolate the payment environment, activate fallback procedures, delay selected customer transfers, preserve evidence, notify regulators, and begin safe restoration.

The exercise is intended to surface tensions between technical containment, business continuity, customer impact, legal or regulatory obligations, media pressure, and safe recovery. It also tests whether participants can connect high-level technical evidence to business decisions without turning the session into a malware-analysis exercise.

5.1 Technical attack lifecycle - facilitator reference

Sequence	Simulated time	Attacker activity	Scenario evidence	ATT&CK anchor
1	T-10 days	Targeted phishing email sent to payment operations staff using a settlement exception theme.	Email security telemetry shows a user clicked a link from an external sender impersonating a payments partner.	T1566.002
2	T-10 to T-9 days	Initial execution occurs on a payment operations workstation and a lightweight remote access component is staged.	EDR process chain shows office/browser activity followed by scripting activity and outbound HTTPS traffic.	T1059, T1071.001
3	T-9 days	Persistence is established on the compromised workstation.	EDR notes persistence artifacts; no technical remediation is performed during the exercise.	T1547.001
4	T-8 days	Local privilege escalation enables access to credential material on the host.	Privilege change and credential access alerts are correlated to the workstation.	T1068, T1003.001
5	T-7 to T-4 days	Discovery of accounts, payment servers, file shares, remote services, and backup administration paths.	SIEM logs show unusual enumeration from the compromised endpoint and payment jump/admin path.	T1087, T1018, T1046
6	T-4 to T-2 days	Valid accounts and remote services are used to reach payment zone systems.	Privileged service account authenticates from an unusual source host and accesses payment servers.	T1078, T1021
7	T-1 day	Defense evasion and ransomware staging occur on selected payment servers.	EDR tamper alerts and suspicious service creation events occur in the payment environment.	T1562.001, T1021
8	T-2 hours	Ransomware encryption begins on payment processing servers and shared operations drives.	Batch failures, inaccessible shares, ransom notes, and file extension changes are reported.	T1486
9	T-2 hours onward	Recovery inhibition attempts are observed.	Backup console alerts show suspicious backup catalog access and local recovery deletion attempts.	T1490

Core evidence boundary

The core scenario does not confirm data exfiltration. Participants may ask whether double extortion is possible, but communications should avoid stating that data was stolen unless the optional extension is introduced.

5.2 Simulated evidence available to facilitators

- **SOC alert** EDR identifies ransomware behavior on payment processing servers and operations file shares.
- **Identity alert** A privileged service account used for payment operations authenticates from an unusual workstation and remote administration path.
- **Network alert** The compromised workstation shows periodic outbound HTTPS traffic to external infrastructure prior to encryption.
- **Backup alert** Backup console telemetry indicates suspicious backup catalog access and attempts to remove local recovery points.
- **Operations alert** Payment batch failures and backlog growth become visible approximately two hours before settlement cut-off.
- **Ransom note** An enterprise ransomware note claims responsibility and threatens business disruption. Any data theft claim remains unverified in the core scenario.

6. Participant Roles

Group	Participants	Primary decisions and focus
Executive / Crisis Management	Executive sponsor / crisis lead; COO delegate; CISO or delegate; business line leadership for payments	Incident posture, crisis activation, business risk acceptance, continuity activation, customer and regulator posture, decision logging.
Operational / Business	Head of payment operations; treasury/liquidity representative; settlement operations lead; customer service or relationship management; business continuity lead	Payment prioritization, settlement obligations, manual fallback capacity, backlog management, customer impact, operational workarounds.
Technical / Response	SOC lead; incident response lead; infrastructure/platform operations; backup and recovery; identity and access management	Containment, blast-radius scoping, evidence preservation, credential controls, backup validation, safe restoration gates.
Control Functions	Legal counsel; compliance/regulatory affairs; privacy office; risk management	Notification thresholds, privilege and evidence handling, decision rationale, regulatory communications, risk reporting.
Communications	Corporate communications; media relations; internal communications; client-facing coordination	Message consistency, stakeholder updates, customer impact statements, rumor management, media holding statements.
Observers / Scribes	Exercise observers; decision log owner	Capture decisions, unresolved assumptions, escalation timing, gaps, and action items.

Role clarity principle

The SOC and incident response team should recommend and execute technical containment actions within pre-approved emergency authority. The crisis cell should not micromanage technical containment, but it must understand business consequences, approve continuity mode, determine payment prioritization, coordinate stakeholder communications, and accept residual business risk where required.

7. Facilitation Guidance

Activity	Suggested duration	Facilitator objective
Introduction, objectives, roles, and rules	10 minutes	Set safe-learning tone; confirm decision log owner; clarify SOC versus crisis-cell responsibilities.
Inject 1 discussion	15 minutes	Test incident classification, containment initiation, evidence preservation, and rapid business impact assessment.

Activity	Suggested duration	Facilitator objective
Inject 2 discussion	20 minutes	Force executive decision on isolation, continuity fallback, payment prioritization, and regulatory preparation.
Inject 3 discussion	20 minutes	Test restoration gates, backup validation, evidence preservation, communications, and backlog management.
Inject 4 discussion	15 minutes	Test notifications, customer handling, post-incident governance, and corrective action planning.
Debrief and lessons learned	10 minutes	Capture gaps, owners, due dates, and improvement priorities.

What facilitators should watch for

- Clarity of authority for declaring an incident, activating crisis management, isolating systems, activating continuity, and approving restoration.
- Whether participants distinguish containment from recovery and business continuity from technical remediation.
- Whether participants consider evidence preservation before rebuilding, restoring, or wiping affected systems.
- Whether the group recognizes that use of valid credentials increases the need for credential reset, session revocation, account review, and service account monitoring.
- Whether communications are synchronized across SOC/IR, executives, operations, legal/compliance, client-facing teams, and regulators.
- Payment prioritization logic, including who owns the decision and what criteria are used.
- Escalation thresholds and timing of preliminary regulatory notification or consultation.
- Whether the team avoids ungrounded statements about data exfiltration, attribution, or recovery timelines.

Audience-level prompts

Audience	Primary prompts
Executives	What decisions do you need in the next 15 minutes? What risk are you accepting if processing continues? What message can you defend to regulators and customers?
Operations	Which payments must move first? What workarounds exist and what controls compensate for manual processing? What backlog information can be trusted?
Technical responders	What evidence confirms blast radius? What can be isolated immediately? What credentials, sessions, services, and backups must be protected before restoration?
Legal/compliance	What notification thresholds may be triggered? What facts are known versus suspected? What wording avoids overstatement while meeting obligations?
Communications	What holding statement is accurate now? How will messages differ for employees, clients, counterparties, payment partners, and media?

8. Detailed Scenario Timeline and Injects

Inject 1: Operational Disruption and Confirmed Encryption Alerts

Simulated time: T-2 hours before end-of-day settlement

Inject

Payment operations reports failed payment batches and a growing processing backlog. The SOC confirms ransomware behavior on payment processing servers and associated operations file shares. Several payment workflows are degraded or unavailable, and teams report they may miss settlement deadlines if the disruption continues.

What participants know

- Payment batches are failing in the retail payment processing environment.
- Shared operations drives used by payment teams are becoming inaccessible.
- Ransomware activity has been confirmed on payment processing servers.
- End-of-day settlement is two hours away.
- Customer transfers, domestic payments, and selected priority flows may be impacted.
- A privileged payment service account has authenticated from an unusual source host.
- There is no confirmed data exfiltration at this time.

Technical evidence presented

- EDR: file encryption behavior on payment servers and operations shares.
- SIEM: unusual service-account authentication path from a payment operations workstation to payment infrastructure.
- Endpoint telemetry: earlier scripting activity and external HTTPS beaconing from the compromised workstation.
- Backup telemetry: suspicious backup catalog access and attempted removal of local recovery points.

Discussion questions

- What is the immediate incident classification and who is accountable for directing response actions?
- What technical containment actions should the SOC/IR team take now under emergency authority?
- Which systems, user groups, sessions, service accounts, and interfaces must be isolated immediately, and which should remain available if safe?
- What evidence must be preserved before any rebuild, restore, or credential reset?
- Which business services and payment flows are most critical in the next two hours?
- What criteria determine whether fallback procedures should be activated now versus later?
- What information is needed within the next 15 to 30 minutes to support executive decisions?
- Who must be informed internally at this stage, and what should the message say?

Expected actions

- Establish incident command, executive awareness, and a decision log.
- Validate scope of encryption, identity compromise, and likely blast radius.
- Contain affected servers, isolate compromised workstations, restrict lateral movement paths, and suspend suspicious privileged/service-account use where operationally safe.
- Preserve logs, volatile artifacts, authentication records, backup telemetry, ransom notes, and payment-batch status records.
- Launch a rapid business impact assessment focused on settlement, customer obligations, liquidity, and payment queue visibility.

- Prepare continuity and payment prioritization options for executive decision.
- Prepare preliminary regulator and stakeholder notification materials without confirming facts not yet known.

Optional facilitator artifact

SOC Alert Summary - Exercise Artifact

EDR has detected bulk file modification consistent with ransomware on two payment processing servers. A payment operations shared drive is unavailable. Identity logs show privileged service account use from a workstation outside the normal administrative path. Backup console telemetry shows suspicious catalog access.

Facilitator notes

Facilitator cue

Strong responses should avoid jumping directly to restoration. Look for rapid scoping, emergency containment, evidence preservation, identity containment, and business impact assessment. Challenge vague statements such as 'the SOC will handle it' or 'we will restore backups' without identifying gates, owners, and business consequences.

Inject 2: Executive Decision Point Before Settlement Cut-Off

Simulated time: T-90 minutes before settlement cut-off

Inject

Executives must decide whether to isolate the entire payment environment, activate manual fallback processes, delay selected customer transfers, and notify the regulator before settlement cut-off. Operations advises that some priority payments may still be completed through documented workarounds if specific dependencies remain available. The SOC advises that continued partial processing could leave active attacker access paths in place unless strict isolation and account controls are implemented.

What participants know

- The ransomware is active in the payment zone.
- Full isolation would likely reduce further damage but may halt additional payment processing.
- Partial operations may still be possible through fallback procedures with reduced throughput and increased manual-control needs.
- Settlement deadlines are approaching quickly.
- Customer and counterparty impact will become visible soon.
- Identity compromise is plausible because privileged/service-account use has been observed from an abnormal source.
- The backup team has not yet validated whether clean, restorable backups are available for all affected payment systems.

Technical evidence presented

- IR recommends disabling or rotating affected privileged credentials and revoking active sessions, but warns this may interrupt some fallback processing.
- Network team can isolate the payment subnet, file shares, and jump/admin paths, but the exact dependency impact is not fully mapped.
- Backup team sees no successful destruction of central backups, but local recovery artifacts on some hosts may be unavailable.

Discussion questions

- Who has authority to order full isolation of the payment environment, and what pre-approved authority does SOC/IR already have?
- What is the threshold for switching from standard operations to continuity mode?
- Which payment types should be prioritized and why?

- Should the bank delay lower-priority customer transfers to preserve capacity for critical obligations?
- What legal, reputational, operational, and cyber risks arise from continued partial processing?
- What regulatory notifications or consultations may be required before settlement cut-off?
- What should be communicated to customers, counterparties, payment partners, front-line staff, and internal executives?
- How will the organization avoid making unsupported claims about root cause, data theft, attribution, or recovery timelines?

Expected actions

- Make a time-bound executive decision on containment versus continuity, with explicit risk acceptance.
- Confirm SOC/IR authority to isolate affected segments, disable compromised paths, revoke sessions, and protect evidence.
- Activate manual or alternate payment processing for priority transactions if authorized.
- Implement payment triage based on business criticality, contractual obligations, regulatory requirements, customer harm, and liquidity implications.
- Prepare regulator notification decisioning and draft key messages based on confirmed facts.
- Establish communication channels for front-line operations, relationship managers, payment partners, and executive leadership.
- Define a short-cycle cadence for situation updates, decision review, and backlog reporting.

Optional facilitator artifact

Executive Decision Card - Exercise Artifact

Decision required within 15 minutes: full payment-zone isolation, limited continuity processing, or continued partial operations under enhanced controls. Current known risk: ransomware active in payment zone; identity compromise plausible; settlement cut-off in 90 minutes.

Facilitator notes

Facilitator cue

This phase should expose governance gaps. Participants should articulate decision rights, prioritization criteria, and how they balance operational continuity against risk of further compromise. Push for clear ownership: SOC recommends and executes technical containment; crisis management owns business consequences and external posture.

Inject 3: Containment Stabilized, Restoration Decisions Begin

Simulated time: Several hours later

Inject

Containment measures have reduced further spread within the payment zone. However, encryption has rendered multiple payment servers and shared operational resources unavailable. The incident response team advises that restoration should not begin until evidence is preserved, privileged credentials are reset or contained, backups are validated, and recovery sequencing is approved. Some manual fallback processing has started, but backlog and customer delay pressure are increasing.

What participants know

- The immediate spread appears limited, but full eradication is not yet confirmed.
- Priority payments are being managed through fallback methods with reduced capacity.
- Customer delays are accumulating and some relationship managers are receiving inquiries.
- Communications pressure is increasing from internal stakeholders and major clients.

- Recovery sequencing decisions are needed.
- Backup catalog integrity appears intact, but selected local recovery points are unavailable.
- No confirmed data exfiltration has been identified, despite a generic ransomware note threatening disclosure.

Technical evidence presented

- Forensic team has preserved memory, relevant logs, ransom notes, authentication records, and selected disk images.
- Identity team has prepared privileged-account reset sequencing and service-account review.
- Backup team has validated one clean pre-compromise backup set for core payment processing, but restoration testing is incomplete.
- Network team can maintain segmentation while systems are restored in a clean recovery enclave.

Discussion questions

- What conditions must be met before restoration begins?
- How should the organization sequence recovery of payment servers, file shares, interfaces, user access, service accounts, and reconciliation capabilities?
- How does the team validate backups and ensure restored systems are safe before reconnection?
- What evidence preservation steps are mandatory before rebuilding or restoring systems?
- What additional notifications or regulator updates are required as impact becomes clearer?
- How should the organization manage media, customer, and regulator inquiries if delays become public?
- How should the organization communicate uncertainty about exfiltration without under- or over-stating the risk?

Expected actions

- Approve a restoration decision framework with technical, business, legal, and risk sign-off.
- Prioritize recovery of systems enabling settlement, payment visibility, reconciliation, and customer-impact assessment.
- Validate backup integrity, restoration safety, malware absence, credential hygiene, and segmentation before reconnecting systems.
- Continue fallback processing where necessary using enhanced manual controls and reconciliation checks.
- Update leadership, regulators, client-facing teams, and operational stakeholders with realistic timelines, known impacts, and decision dependencies.
- Maintain a separate track for root-cause analysis and control remediation without delaying critical service recovery unnecessarily.

Optional facilitator artifact

Recovery Gate Checklist - Exercise Artifact

Gate 1: evidence preserved. Gate 2: compromised credentials contained. Gate 3: clean backup verified. Gate 4: restored system scanned and monitored. Gate 5: business owner accepts service readiness. Gate 6: regulator/customer messaging updated.

Facilitator notes

Facilitator cue

Good answers should include restoration gates, backup validation, credential reset sequencing, forensic preservation, and a clearly sequenced service recovery plan. Challenge any answer that treats backup restoration as a single action or ignores identity compromise.

Inject 4: Recovery, Notification, and Post-Incident Management

Simulated time: Next business period

Inject

The payment environment is being restored in a controlled sequence. Critical systems are returning, but some transfers were delayed and selected customers experienced disruption. Executives must determine the scope of regulator communications, customer messaging, internal reporting, and post-incident review actions. The SOC has found no confirmed evidence of data exfiltration in the core scenario, but ongoing monitoring continues.

What participants know

- Core payment capabilities are returning.
- The backlog is being worked through in priority order.
- Settlement disruption was at least partially realized.
- Selected customer transfers were delayed and customer-facing teams require approved messaging.
- The incident may trigger internal reporting, external notifications, regulator follow-up, and formal lessons-learned activities.
- Root-cause analysis points to phishing, credential misuse, insufficient service-account monitoring, and gaps in segmentation or recovery readiness.

Technical evidence presented

- Clean restoration is complete for critical payment processing; shared operations drives are being restored in phases.
- Affected privileged and service accounts have been reset, disabled, or reauthorized under enhanced monitoring.
- No confirmed exfiltration evidence has been found in proxy, DLP, or forensic review; monitoring will continue.
- Some backup and recovery controls require remediation because local recovery artifacts were successfully inhibited on affected servers.

Discussion questions

- What should be included in regulator notifications or follow-up reporting?
- How should the bank communicate with affected customers and counterparties?
- What controls or gaps most likely contributed to the incident impact?
- What immediate risk reduction measures should be implemented before normal operations fully resume?
- What metrics, decisions, and timelines should be captured in the post-incident review?
- How will management track corrective actions to closure?
- What evidence supports the statement that exfiltration is not confirmed?

Expected actions

- Complete stakeholder communications and regulatory reporting as required.
- Finalize business and technical recovery validation, including reconciliation and payment backlog integrity checks.
- Document decision timelines, incident classification, impact, communication approvals, and escalation effectiveness.
- Launch after-action review and remediation planning.
- Track corrective actions relating to phishing resilience, service-account controls, segmentation, backup readiness, continuity procedures, detection, and authority clarity.
- Define a monitoring period and reporting cadence for residual risk, delayed payment exceptions, and customer complaints.

Optional facilitator artifact

Post-Incident Reporting Prompt - Exercise Artifact

Prepare a concise management update: material facts, timeline, systems affected, customer impact, settlement impact, containment actions, recovery status, evidence regarding data exposure, regulator/customer communications, and corrective action owners.

Facilitator notes

Facilitator cue

This final phase should draw out lessons learned, not just closure. Participants should identify specific improvements in resilience, governance, communications, technical control coverage, and restoration readiness. Make sure the team distinguishes 'no evidence of exfiltration' from 'exfiltration impossible.'

Optional extension: suspected data leak claim

Facilitators may introduce this extension only if the exercise needs an additional legal, privacy, communications, or double-extortion decision point.

Optional Inject 5 - Unverified leak claim

A threat actor posts a generic claim on a criminal forum alleging possession of payment operations data. No sample data has been validated. Participants must decide how to investigate, preserve evidence, notify stakeholders, and communicate without confirming a breach prematurely. If played, add ATT&CK T1041 only if forensic evidence later confirms exfiltration over command-and-control or another outbound channel.

9. Decision Points Summary

Decision	Owner / accountable role	Decision criteria	Expected output
Declare incident severity and activate crisis management	CISO/SOC lead with crisis lead	Confirmed ransomware behavior, payment disruption, identity compromise indicators, settlement timing	Incident classification, command structure, meeting cadence, decision log
Isolate affected payment systems or full payment environment	SOC/IR for emergency containment; crisis lead for business risk posture	Blast radius, active compromise evidence, settlement dependencies, fallback capacity	Isolation scope, dependency exceptions, compensating controls
Disable, reset, or contain privileged/service accounts	IAM lead with SOC/IR and business owner input	Suspicious authentication, service dependency, operational continuity risk	Credential action plan and service restoration impacts
Activate payment continuity fallback	Payments business lead and crisis lead	Settlement obligation, customer harm, manual capacity, reconciliation controls	Continuity mode declaration and transaction prioritization
Prioritize payment flows under degraded conditions	Payments operations and treasury with executive approval	Regulatory/settlement criticality, liquidity impact, customer harm, contractual obligations	Approved payment prioritization list
Delay or suspend selected customer transfers	Business executive with legal/compliance input	Risk of unsafe processing, customer impact, regulatory expectations, operational capacity	Delay criteria and customer messaging
Notify regulators or consult supervisors	Compliance/legal with crisis lead approval	Material disruption, unauthorized access indicators, customer impact, jurisdictional thresholds	Initial notification or consultation package
Begin restoration	Technology recovery lead with SOC/IR, business, and risk sign-off	Evidence preserved, clean backups validated, credentials contained, restored systems monitored	Restoration gate approval
Communicate externally	Communications lead with legal/compliance and business approval	Confirmed facts, stakeholder needs, regulatory posture, media/customer visibility	Holding statement, client FAQ, internal briefing

10. Business and Technical Impacts to Explore

Impact category	Impacts to discuss	Facilitator probes
Business impacts	Missed or delayed settlement deadlines; delayed customer transfers and complaints; liquidity management pressure; increased manual processing workload; customer service surge; reputational scrutiny from counterparties, partners, and regulators.	Which impacts are material? Who validates them? How are impacts quantified and updated?
Operational impacts	Loss of payment queue visibility; fallback process bottlenecks; manual approval and four-eyes control strain; reconciliation delays; dependency uncertainty across payment rails and settlement partners.	How much manual capacity exists? What controls prevent payment errors under pressure?
Technical impacts	Encryption of payment servers and shared drives; compromised workstation; suspicious privileged/service-account use; impaired endpoint security on some hosts; attempted inhibition of local recovery artifacts; backup and restore validation requirements.	How does the team prove the environment is clean enough to reconnect?
Legal / regulatory impacts	Potential notification or consultation requirements; preservation of evidence; customer harm assessment; privacy assessment if exfiltration remains unconfirmed; post-incident report expectations.	What facts are known, suspected, or unknown? What must be updated later?
Communications impacts	Internal rumor control; customer and counterparty updates; consistent executive briefing; external holding statement if disruption becomes public.	What should be said now versus after validation?

11. Success Criteria

The exercise is successful if participants can:

- Clearly identify incident leadership, technical containment authority, business decision authority, and external communication approval paths.
- Make timely containment and continuity decisions with incomplete but sufficient information.

- Prioritize critical payment flows under time pressure using documented and defensible criteria.
- Align SOC/IR, technology recovery, operations, legal, compliance, communications, and executive actions.
- Use technical indicators to inform containment and recovery without requiring deep malware analysis.
- Demonstrate a credible approach to regulator, customer, partner, and internal communications.
- Define safe restoration criteria, including evidence preservation, backup validation, credential hygiene, and recovery sequencing.
- Avoid unsupported claims about data exfiltration, attribution, or recovery certainty.
- Identify concrete improvements after the exercise with owners and target dates.

12. Debrief Questions

- What decisions were made well, and why?
- Where were authorities, escalation paths, or accountabilities unclear?
- Did the group understand when SOC/IR could act under emergency technical authority versus when executive risk acceptance was required?
- Was the threshold for activating continuity procedures well understood?
- Did participants have enough information to prioritize payments effectively?
- Were communications timely, accurate, and appropriately coordinated?
- Did the organization demonstrate a safe and realistic restoration approach?
- How did participants handle uncertainty about data exfiltration and ransomware claims?
- Which technical control gaps most affected the scenario: phishing resilience, credential access, service accounts, segmentation, EDR tamper protection, backups, or monitoring?
- What capabilities, playbooks, dependencies, or decision templates need improvement?

Observer confidence ratings

Statement	1	2	3	4	5
We can rapidly classify and escalate a ransomware event affecting payment operations.					
We understand who can order payment-zone isolation and who accepts business consequences.					
We can activate fallback payment processing with clear prioritization and compensating controls.					
We can preserve evidence while moving toward safe recovery.					
We can validate backups and restore payment services in a controlled sequence.					
We can communicate accurately with regulators, customers, partners, and employees under uncertainty.					

13. Recommended Improvement Areas

Theme	Potential improvement actions
Payment environment segmentation and containment readiness	Validate isolation runbooks, dependency maps, jump/admin path controls, emergency change approvals, and exception handling for continuity processing.
Identity and service-account controls	Review privileged/service-account scope, interactive logon restrictions, tiering, rotation procedures, session revocation, abnormal use detection, and emergency credential reset plans.

Theme	Potential improvement actions
Phishing resilience and access controls	Strengthen email detection, user reporting, phishing-resistant MFA where feasible, conditional access, impossible-travel review, and high-risk session controls.
Endpoint and server detection	Review EDR coverage, tamper protection, script execution monitoring, ransomware behavior alerts, and SOC escalation thresholds for payment-zone assets.
Backup integrity and recovery rehearsal	Confirm immutable or offline backups for critical payment systems; rehearse clean recovery, backup catalog protection, and restoration validation.
Payment continuity and prioritization	Update fallback playbooks, capacity assumptions, priority payment criteria, manual four-eyes controls, and reconciliation controls.
Executive decision frameworks	Create decision cards for isolation, continuity activation, payment triage, regulator notification, and restoration gates.
Regulatory and customer communications	Prepare templates for preliminary notification, follow-up reporting, customer FAQs, and media holding statements that distinguish known facts from assumptions.
Forensic preservation and recovery gates	Document evidence preservation minimums, restoration approval gates, forensic image requirements, log retention, and post-incident root-cause handoffs.

14. MITRE ATT&CK Mapping

The following mapping reflects tactics and techniques that are explicitly represented in the revised scenario. Confidence indicates how directly the technique is grounded in the tabletop narrative. Techniques are described at a level suitable for exercise discussion and do not include operational instructions.

Tactic	Technique	Scenario grounding	Exercise use	Confidence
Initial Access	T1566.002 - Spearphishing Link	Payment operations user receives a targeted settlement exception lure and interacts with a malicious link.	Discuss phishing reporting, email controls, conditional access, and initial triage.	High
Execution	T1059 - Command and Scripting Interpreter	EDR observes scripting activity following user interaction on the compromised workstation.	Discuss endpoint detection, isolation, and evidence preservation.	High
Persistence	T1547.001 - Registry Run Keys / Startup Folder	Persistence artifacts are observed on the compromised workstation before lateral movement.	Discuss eradication criteria and rebuild versus clean-up decisions.	Medium
Privilege Escalation	T1068 - Exploitation for Privilege Escalation	A local privilege escalation condition is inferred from telemetry and credential access alerts on the workstation.	Discuss patch posture, least privilege, and containment priority.	Medium
Defense Evasion	T1562.001 - Disable or Modify Tools	EDR tamper and suspicious security-control impairment alerts occur on selected payment systems.	Discuss tamper protection, alert priority, and trust in endpoint state.	High
Credential Access	T1003.001 - LSASS Memory	Credential access artifacts are correlated to later abnormal privileged/service-account use.	Discuss credential reset sequencing, service-account monitoring, and session revocation.	High
Discovery	T1087 - Account Discovery	Enumeration of domain users, admins, and service accounts occurs before ransomware deployment.	Discuss detection of reconnaissance and privileged account exposure.	High
Discovery	T1018 - Remote System Discovery	Payment servers, operations file shares, and administration paths are enumerated.	Discuss asset inventory and blast-radius scoping.	High
Discovery	T1046 - Network Service Discovery	Scanning or probing of reachable services in the payment zone is observed.	Discuss network visibility and segmentation.	Medium
Lateral Movement	T1021 - Remote Services	Valid credentials and remote administration paths are used to reach payment servers.	Discuss isolation of jump paths, session review, and remote access controls.	High
Valid Account Use	T1078 - Valid Accounts	A privileged service account authenticates from an unusual workstation/source path.	Discuss account ownership, monitoring, emergency disablement, and service continuity.	High
Command and Control	T1071.001 - Web Protocols	Compromised workstation shows outbound HTTPS beaconing before encryption.	Discuss proxy monitoring, egress control, and escalation of suspicious external communications.	High
Impact	T1486 - Data Encrypted for Impact	Ransomware encrypts payment servers and operations shared drives, disrupting payment batches.	Discuss containment, continuity, backlog, and recovery priorities.	High
Impact	T1490 - Inhibit System Recovery	Backup catalog access and local recovery deletion attempts are observed.	Discuss backup protection, restoration gates, and recovery validation.	High
Optional only	T1041 - Exfiltration Over C2 Channel	Not part of the core scenario. Map only if optional leak extension is played and forensic evidence confirms outbound data transfer.	Discuss evidence standards and communications under uncertainty.	Not core

ATT&CK facilitator notes

- T1486 remains the central direct technique because encryption of payment systems is the primary scenario impact.
- T1490 is no longer speculative because the revised scenario includes backup catalog access and local recovery disruption attempts.

- T1041 is deliberately excluded from the core mapping. Facilitators should not treat exfiltration as confirmed unless the optional extension is played and evidence is introduced.
- The pre-impact techniques are included to improve training value for SOC, IR, IAM, infrastructure, and technology recovery participants while preserving the executive and operational focus of the exercise.

15. Appendix: STIX-to-Scenario Translation and Feedback Integration

Key structured scenario elements used

- Target organization: Banking organization in financial services.
- Threat actor: Financially motivated ransomware operator.
- Infrastructure targeted: Retail payment processing environment.
- Malware: Enterprise ransomware payload.
- Attack pattern: Encryption of payment operations systems to disrupt settlement.
- Incident: Ransomware affecting retail payment operations.
- Courses of action: Activate payment continuity fallback; contain and preserve evidence in the payment zone; validate backups; restore safely.

Design logic

- Translated the structured incident into timed injects aligned to settlement pressure.
- Expanded the attack chain so participants can discuss how the operator gained access, escalated privileges, evaded controls, moved laterally, communicated externally, deployed ransomware, and inhibited recovery.
- Converted technical events into business-relevant decisions, including isolation, continuity, payment triage, communications, and restoration gates.
- Separated confirmed facts from investigative hypotheses to avoid overstatement about exfiltration or attribution.
- Mapped each core technique to scenario evidence rather than listing plausible but unsupported techniques.

Evaluation feedback applied

Feedback theme	How this version addresses it
Attack mechanics underdeveloped	Added a full pre-impact lifecycle from phishing through execution, persistence, privilege escalation, credential access, discovery, lateral movement, C2, defense evasion, ransomware deployment, and recovery inhibition.
Earlier ATT&CK phases vague	Updated injects and facilitator reference tables now include concrete technical indicators and participant prompts for each relevant phase.
T1490 speculative	Grounded T1490 through backup catalog access and local recovery deletion attempts observed during the incident.
T1041 speculative	Removed T1041 from the core scenario; retained only as an optional extension requiring evidence before mapping.
Limited cyber responder training value	Added technical evidence cards, identity/backup decision points, restoration gates, and detailed SOC/IAM/recovery prompts.

16. Optional Visuals for Final PDF Layout

The following visuals are already represented in simplified table form in this facilitator pack and can be converted to branded diagrams if required:

- One-page scenario timeline graphic showing pre-incident compromise through recovery.
- Payment operations dependency map showing payment servers, file shares, identity services, backup infrastructure, interfaces, and manual fallback paths.
- Decision log table for facilitators.
- RACI-style responsibility matrix for containment, continuity, notifications, and restoration.
- MITRE ATT&CK summary table with scenario evidence and confidence.

Facilitator decision log template

Time	Decision / action	Owner	Evidence used	Risk accepted	Communications required	Follow-up

Payment prioritization worksheet

Priority	Payment type / flow	Rationale	Required controls	Approver
1	Settlement-critical obligations and liquidity-sensitive flows	Prevent systemic, regulatory, or severe liquidity impact	Dual approval, manual reconciliation, fraud monitoring, exception log	
2	High-value or time-sensitive customer transfers near cut-off	Reduce customer harm and contractual exposure	Relationship manager validation, manual four-eyes, queue tracking	
3	Standard domestic or low-value customer payments	Process when capacity allows and risk is acceptable	Backlog reporting, customer notice if delayed	
4	Non-urgent or discretionary transfers	Defer to preserve safety and capacity	Document delay rationale and customer messaging	

17. Facilitator Closing Statement

This exercise is intended to help the organization evaluate whether its cyber incident response, payment continuity, crisis governance, identity controls, backup readiness, and regulatory communication processes are sufficient to manage a ransomware event affecting time-sensitive retail payment operations. The emphasis is on practical coordination, timely executive decisions, evidence-based communications, and safe recovery under pressure.

The strongest outcomes are not perfect answers, but clear decisions, documented assumptions, accountable owners, realistic restoration gates, and specific improvements that reduce the likelihood or impact of a similar event.